
개인정보보호암호기술

암호기술 기초와 보안 목표

강원대학교 이세영



이번 시간에 다룰 내용

학습목표

- 01 보안 목표(CIA · 확장 요소)와 보안 공격 · 서비스의 관계를 설명할 수 있다
- 02 암호의 개념과 암호 시스템의 구성요소를 이해한다
- 03 암호를 위한 기초 연산(비트, XOR, 모듈러 연산)을 이해한다
- 04 대칭키 · 공개키 암호 등 암호 기술의 종류와 역할을 구분한다
- 05 공격 모델 · 공격 목표 · 구별 불가능성으로 암호의 안전성을 판단할 수 있다

Contents

01

보안 목표와 보안 서비스

CIA와 확장 보안 요소, 보안 공격의 분류, 보안 서비스와 메커니즘

02

암호학의 기본 개념

암호와 스테가노그래피, 암호학의 분류와 역사, 용어와 암호 시스템

03

암호를 위한 기초 연산

비트와 16진수, XOR, 모듈러 연산, 덧셈 암호의 수학적 표현

04

암호 기술의 종류

대칭키 · 공개키 · 하이브리드 암호, 해시 · MAC · 전자서명

05

암호의 안전성과 공격 모델

케르크호프스 원리, 암호해독, 전사적 공격, COA · KPA · CPA · CCA

06

안전성의 목표와 수준

공격 목표, 구별 불가능성, 무조건적 · 계산적 안전성, 키와 개인정보

보안의 3대 요소 : CIA

기밀성 Confidentiality	무결성 Integrity	가용성 Availability
인가된 사용자만 정보의 내용을 알 수 있음	정보가 인가되지 않은 방법으로 변경되지 않았음을 보장	인가된 사용자가 필요할 때 정보 · 서비스를 사용 가능

요소	깨졌을 때	주요 위협	대표 기술
기밀성	정보 노출 · 도청	도청, DB 탈취, 권한 오남용	암호화, 접근통제
무결성	위 · 변조, 신뢰 상실	메시지 변조, 기록 조작, 재전송	해시 함수, MAC, 전자서명
가용성	서비스 중단	서비스 거부 공격, 랜섬웨어, 장애	이중화, 백업

암호기술이 직접 제공하는 목표 = 기밀성 · 무결성
키 분실 = 데이터 영구 복구 불가 → 키 관리는 가용성 문제이기도 함

- "보안은 가장 약한 고리만큼만 강하다" — 세 요소 중 하나라도 무너지면 전체 보안이 무너지짐

확장 보안 요소 : 인증 · 부인방지 · 책임추적성

인증 (Authentication)

- 주체나 출처가 주장하는 바와 일치함을 확인
 - 개체 인증 : 접속한 사용자 · 서버가 진짜인가
 - 메시지 인증 : 메시지가 주장하는 송신자에게서 왔는가 (+ 무결성)

부인방지 (Non-repudiation)

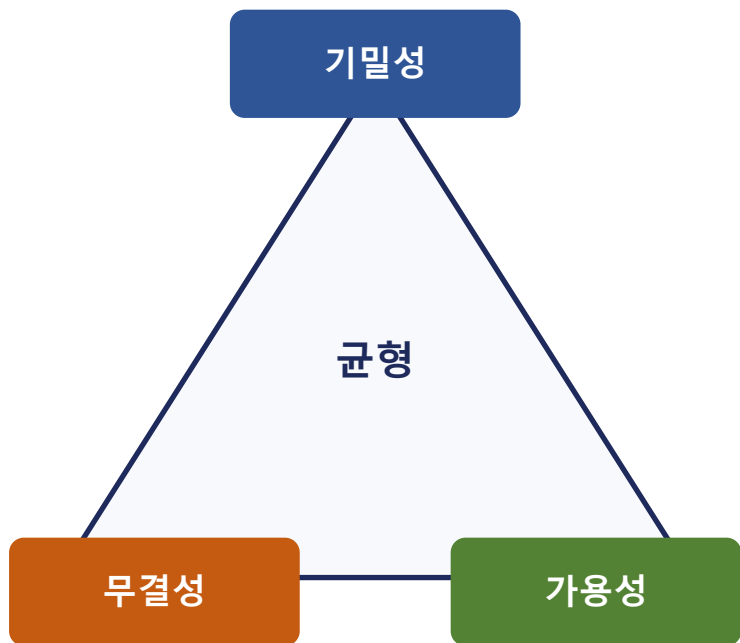
- 행위를 한 주체가 사실을 부인할 수 없게 함
 - 송신 부인방지 · 수신 부인방지
 - 제3자에게도 증명 가능해야 함
 - 행위자만 가진 비밀을 이용 → 전자서명

책임추적성 (Accountability)

- 시스템 내 행위를 특정 주체까지 추적할 수 있는 성질
 - 1인 1계정 원칙, 계정 공유 금지
 - 접속기록 보관과 기록의 위 · 변조 방지
 - 개인정보 보호 법제의 접속기록 보관 의무와 직결

CIA + 인증 · 부인방지 · 책임추적성 = 실제 시스템이 요구하는 보안 목표의 집합

보안 목표 사이의 관계와 균형



조치	강화되는 목표	약화될 수 있는 목표
강한 암호화 + 극소수만 키 보유	기밀성	가용성 (키 분실 · 부재)
로그인 실패 시 즉시 계정 잠금	기밀성 · 인증	가용성 (고의적 잠금 공격)
여러 곳에 데이터 백업	가용성	기밀성 (유출 지점 증가)
모든 요청에 서명 · 검증	무결성 · 부인방지	가용성 · 성능

보안 설계 = 보호 대상과 위험을 먼저 정하고, 목표 사이의 균형점을 찾는 일
→ 개인정보 보호 법제도 "위험에 비례한 조치"를 요구

- 암호기술은 목표를 먼저 정한 뒤 선택해야 함 (기술이 목표를 대신하지 않음)

보안 공격의 분류 : 소극적 공격과 적극적 공격

소극적 공격 (Passive Attack)

- 정보를 관찰 · 수집만 함 (변경 없음)
 - 도청, 트래픽 분석
- 탐지 매우 어려움 → 예방 중심
 - 핵심 대책 : 암호화

적극적 공격 (Active Attack)

- 정보를 변경 · 삭제 · 생성함
 - 신분 위장, 재전송, 메시지 변조, 서비스 거부
- 완전 예방 어려움 → 탐지 · 복구 중심
 - 핵심 대책 : 인증 · 무결성 검증 · 기록 · 백업

공격	구분	침해되는 목표	대응 방법
도청	소극적	기밀성	암호화 (저장 · 전송)
트래픽 분석	소극적	기밀성	통신 패턴 은닉
신분 위장	적극적	인증	개체 인증, 전자서명
재전송	적극적	무결성 · 인증	일회성 값, 시각 정보, 순서번호
메시지 변조	적극적	무결성	해시 함수, MAC, 전자서명
서비스 거부	적극적	가용성	트래픽 필터링, 이중화

01. 보안 목표와 보안 서비스

보안 서비스와 보안 메커니즘 (ITU-T X.800)



서비스 w 메커니즘	암호화	전자 서명	접근 통제	데이터 무결성	인증 교환	트래픽 패딩	라우팅 통제	공증
개체 인증	●	●			●			
데이터 출처 인증	●	●						
접근통제			●					
기밀성	●						●	
트래픽 흐름 기밀성	●					●	●	
데이터 무결성	●	●		●				
부인방지		●		●				●

암호화 · 전자서명 = 가장 많은 서비스의 기반 메커니즘
부인방지 = 전자서명 · 공증 필요 (암호화만으로는 불가)

보안 목표와 개인정보 보호 요구의 연결

개인정보 보호법 제29조 : 개인정보가 분실 · 도난 · 유출 · 위조 · 변조 또는 훼손되지 아니하도록 안전성 확보에 필요한 기술적 · 관리적 및 물리적 조치를 하여야 한다

법이 막으려는 침해	보안 목표	대표 암호 · 보안 기술
분실 · 도난 · 유출	기밀성	저장 · 전송 시 암호화, 접근통제
위조 · 변조	무결성	해시 함수, MAC, 전자서명
훼손	무결성 · 가용성	백업, 무결성 검증
접속기록 보관 · 점검	책임추적성	기록의 위 · 변조 방지
취급자 · 이용자 확인	인증	비밀번호, 일회용 비밀번호, 인증서

법의 언어(침해 유형) → 보안 목표 → 암호기술
= 이 과목 전체의 흐름

02. 암호학의 기본 개념

암호란 무엇인가



crypto(비밀) + graphy(쓰기)
= 비밀스럽게 쓰는 기술

전통적 암호 → 현대 암호학

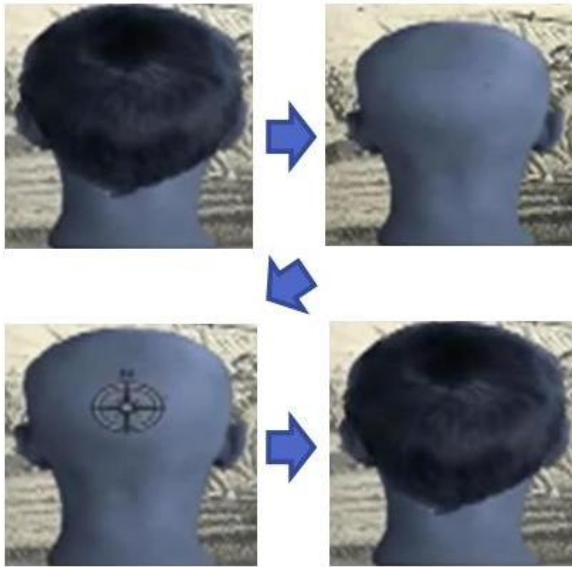
- 전통 : 기밀성 (특정인만 알아보게 함)
- 현대 : 기밀성 + 무결성 + 인증 + 부인방지
 - 키 설정 등 암호 프로토콜까지 포함
- 방법을 숨기는 기술 → 수학적으로 정의 · 분석하는 과학

인터넷 뱅킹 한 번에 사용되는 암호의 역할	보안 목표
은행 서버가 진짜인지 확인	인증
통신에 사용할 비밀 키를 안전하게 정함	기밀성의 전제
주고받는 데이터를 암호화	기밀성
내용이 바뀌지 않았는지 검증, 거래 서명	무결성 · 부인방지

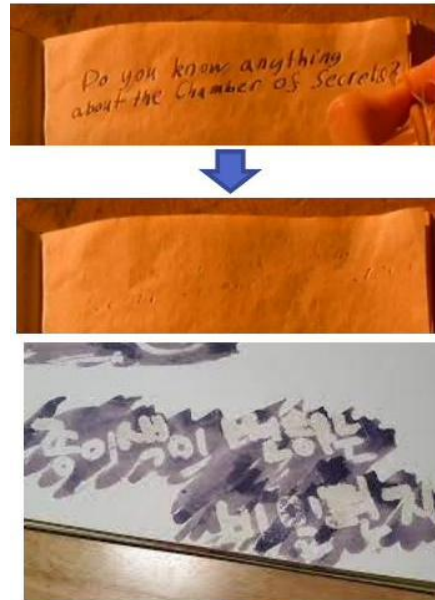
현대 암호 = 방법(알고리즘)은 공개, 안전성은 수학적으로 정의하고 분석

02. 암호학의 기본 개념

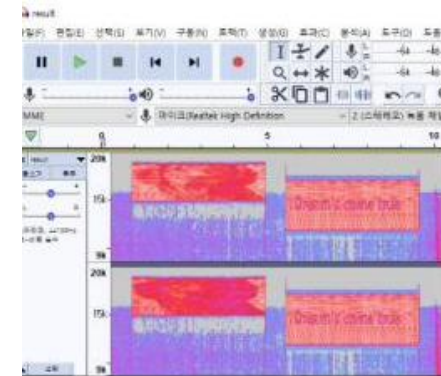
스테가노그래피 (Steganography) 의 예



고대 그리스 히스티에우스의 밀서



이미지 속에
정보 은닉



음악 파일 속에 숨긴 글자 (주파수 분석)

디지털 스테가노그래피

픽셀 값의 최하위 비트 변경

- 1011 0110 → 1011 0111 :
눈으로 구별 불가



불 · 빛 · 화학 처리 (보이지 않는 잉크)

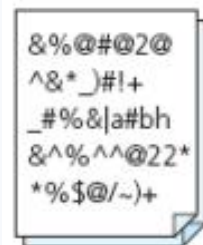
스테가노그래피 = 메시지의 "존재 자체"를 숨기는 기술 (covered writing)

암호와 스테가노그래피의 비교

스테가노그래피 예

데이터를 다루는 모든 순간을 소중히 여기자.
이용자의 믿음은 쉽게 얻을 수 없다.
터진 독은 다시 쌓기 어렵다.
보호는 사고 전에 시작해야 한다.
안전은 습관에서 나온다.

암호 예



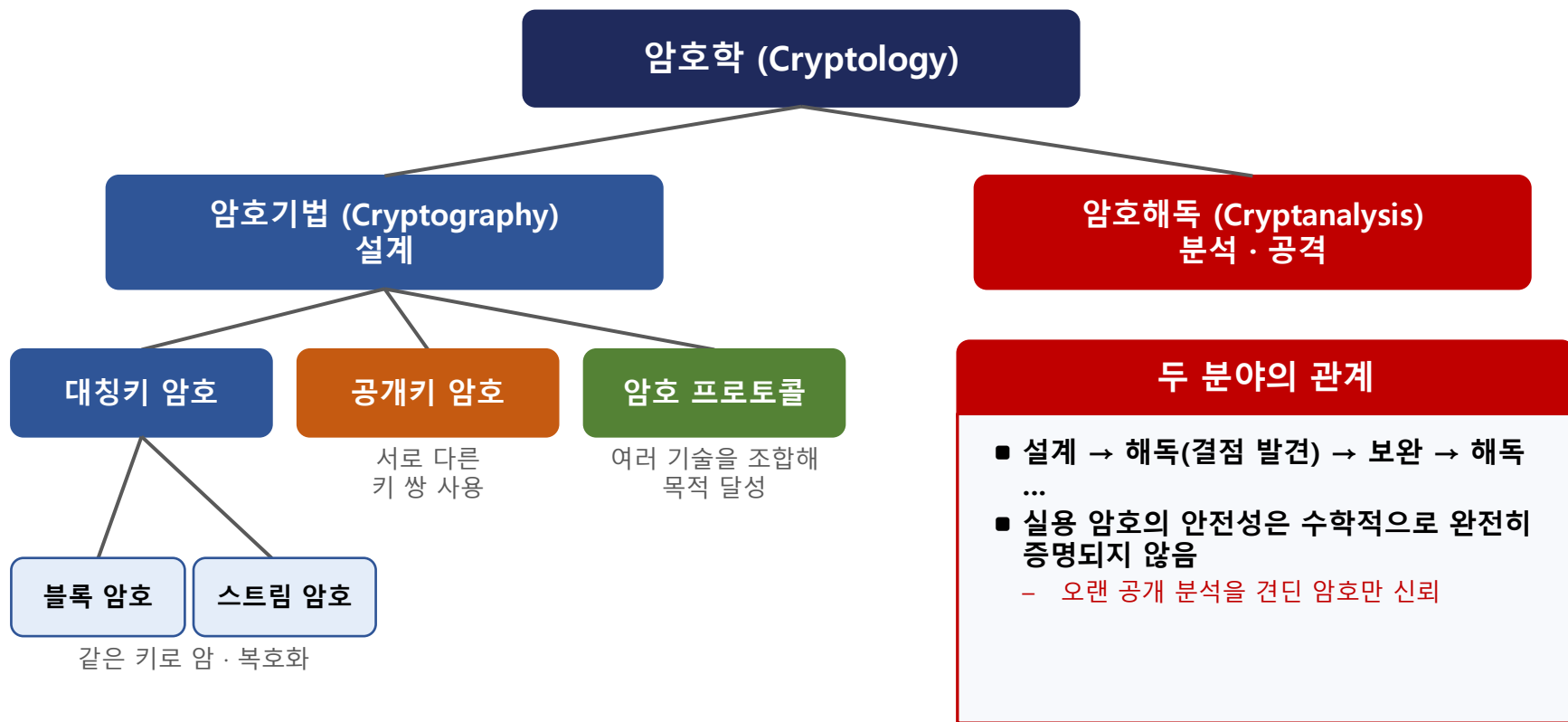
비밀 메시지가 있다는 것은 드러남

그러나 키가 없으면 내용을 알 수 없음

구분	스테가노그래피	암호
숨기는 것	메시지의 존재	메시지의 내용
안전성의 근거	숨긴 방법의 비밀	키의 비밀
방법이 알려지면	내용 즉시 노출	키 없이는 여전히 안전
오늘날의 응용	워터마킹, 유출 추적	저장 · 전송 데이터 보호

스테가노그래피는 암호를 대신할 수 없음 → 필요하면 "암호화한 뒤 숨기기"로 함께 사용

암호학 (Cryptography) 의 분류



암호의 역사 (1) : 고전 암호와 기계식 암호

BC 2000

이집트의
초기 암호 흔적



에니그마와 이를 사용하는 독일군

BC 5C

스키테일
(전치 암호)



BC 1C

시저 암호
(대치 암호)



에니그마 내부 회전자

1918

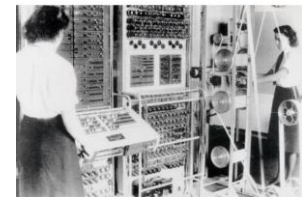
에니그마 발명



앨런 튜링

1940s

에니그마 해독
(튜링 · 봄브)



해독용 컴퓨터

고전 · 기계식 암호 시대의 믿음 : "방법을 숨기고 경우의 수가 많으면 안전하다"
→ 결과 : 모두 해독됨

- 1976년 이전의 모든 암호는 대칭키 방식 (암 · 복호화에 같은 키)

암호의 역사 (2) : 현대 암호의 등장

1883

케르크호프스 원리
안전성은 키에만 의존

1949

샤논의 정보이론
안전성의 수학적 정의

1976

공개키 암호 개념 제안
(디피 · 헬만)

1977

최초의 공개 표준 암호,
공개키 암호 구현

2001

공개 공모 · 검증을
거친 새 표준 블록 암호

2024

양자내성암호
표준 발표

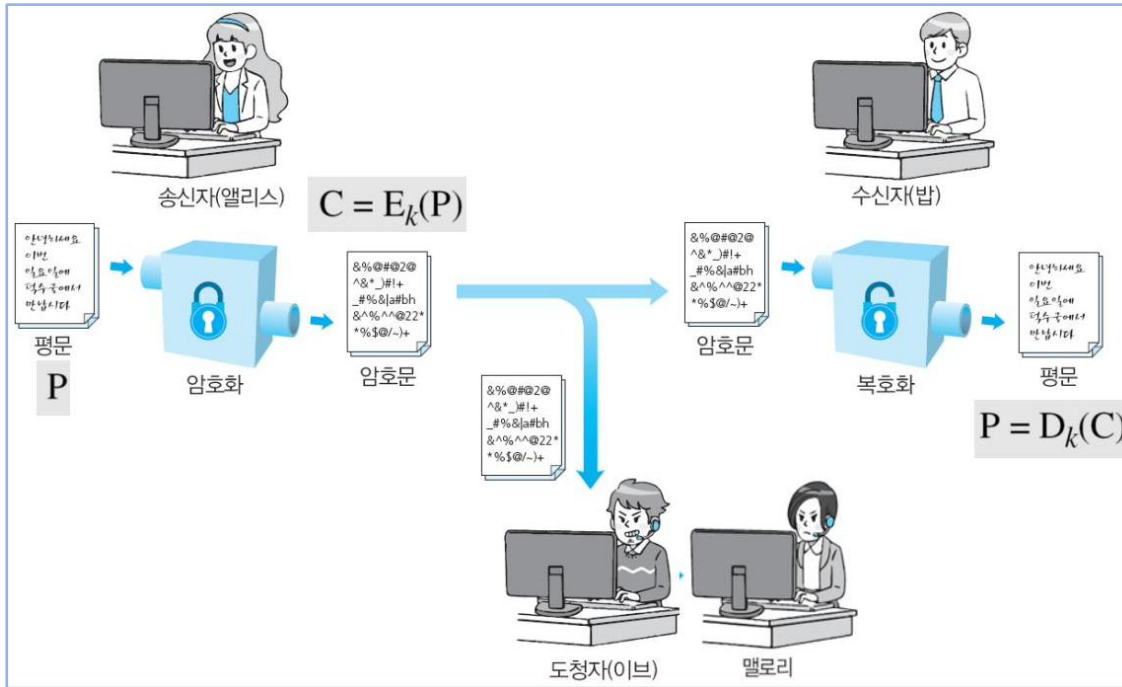


케르크호프스

방법을 숨기는 "기술" → 방법을 공개하고 공개 검증을 거치는 "과학"
(각 암호의 구체적인 구조는 과목의 해당 주제에서 다룸)

02. 암호학의 기본 개념

암호 통신의 등장인물과 기본 용어

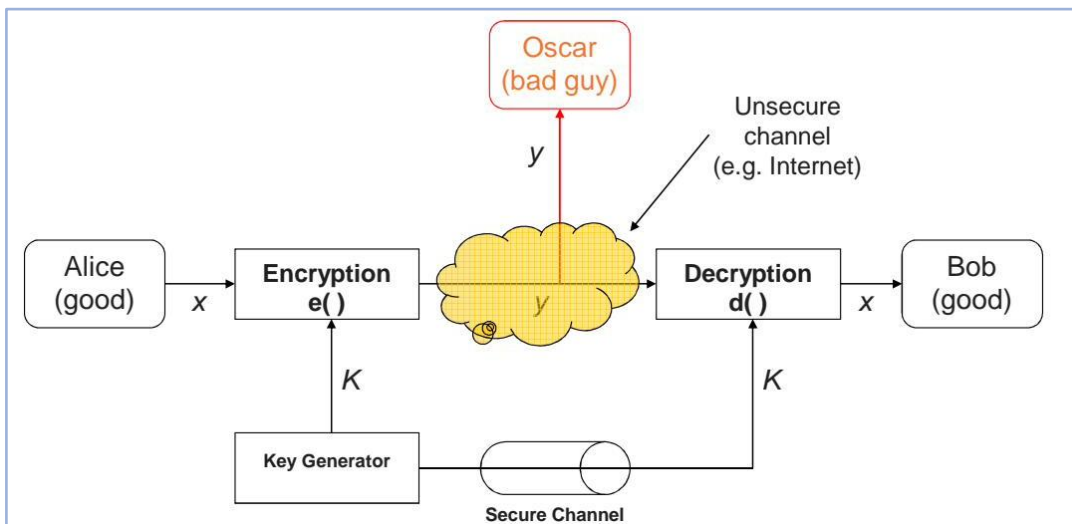


이름	역할	필요한 목표
앨리스 · 밥	정당한 송 · 수신자	—
이브	소극적 공격자 (도청만)	기밀성
멜로리	적극적 공격자 (수정 · 대체 · 재전송)	무결성 · 인증

용어	의미
평문 (Plaintext)	보호하려는 원래 메시지
암호문 (Ciphertext)	알아볼 수 없게 바꾼 메시지
암호화 (Encryption)	평문 → 암호문
복호화 (Decryption)	키를 가진 수신자가 암호문 → 평문
해독 (Cryptanalysis)	키 없이 평문 · 키를 알아내려는 공격

02. 암호학의 기본 개념

암호 시스템의 표기와 키 공간



출처 : Paar & Pelzl, Understanding Cryptography

표기

암호화 : $y = E_K(x)$

복호화 : $x = D_K(y)$

($\rightarrow C = E_K(P), P = D_K(C)$)

정확성 : $D_K(E_K(x)) = x$

키 공간 (Key Space)

- 사용 가능한 모든 키의 집합 $\{K_1, K_2, \dots, K_n\}$
- 크기 = 전사적 공격의 경우의 수
 - k비트 키 $\rightarrow 2^k$ 가지, 1비트 늘면 2배

암호	키 공간 크기
덧셈 암호	26
치환 암호	$26! \approx 2^{88}$

큰 키 공간 = 필요조건
(충분조건 아님)

03. 암호를 위한 기초 연산

비트 · 바이트 · 16진수

10진수	0	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15
2진수	0000	0001	0010	0011	0100	0101	0110	0111	1000	1001	1010	1011	1100	1101	1110	1111
16진수	0	1	2	3	4	5	6	7	8	9	A	B	C	D	E	F

□ 1 바이트 = 8 비트 = 16진수 2자리



$$1010\ 1100_{(2)} = 0xAC = 172_{(10)}$$

문자	10진수 코드	16진수
A	65	0x41
B	66	0x42
a	97	0x61

암호에서의 표현

- 데이터 · 키의 길이는 "비트 수"로 표현
 - 128비트 키 = 16바이트 = 16진수 32자리
- 알고리즘 설명서 · 시험 데이터는 대부분 16진수
- 문자 · 숫자 · 사진 모두 결국 비트열
 - 암호 = 비트열을 변환하는 기술

03. 암호를 위한 기초 연산

배타적 논리합 (XOR, $\oplus$)

XOR 진리표

$\oplus$	0	1
0	0	1
1	1	0

같으면 0, 다르면 1
= mod 2 덧셈

계산 예시

01001100 A

$\oplus$ 10101010 K

= 11100110 $A \oplus K$

$\oplus$ 10101010 K

= 01001100 A 복원

같은 키를 두 번 XOR → 원래 값

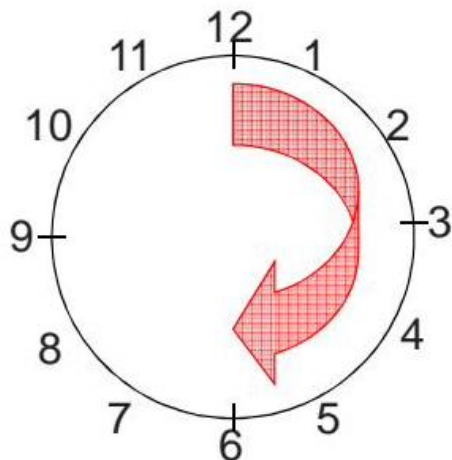
XOR의 성질

- $A \oplus A = 0$
- $A \oplus 0 = A$
- 교환법칙 · 결합법칙
- $(A \oplus K) \oplus K = A$ (상쇄)
- 무작위 K와 XOR → 결과도 무작위처럼 보임

XOR = 암호화와 복호화를 같은 연산으로 + 평문의 특징을 감춤 → 대칭키 암호 설계의 기본 도구

03. 암호를 위한 기초 연산

모듈러 연산 (Modular Arithmetic)



10시 + 5시간 = 3시 ($15 \bmod 12 = 3$)

출처 : Paar & Pelzl, Understanding Cryptography, Ch.1

정의

- $a \bmod m = a$ 를 m 으로 나눈 나머지 r ($0 \leq r < m$)
 - m : 모듈러스 (modulus)
 - $17 \bmod 5 = 2$, $-3 \bmod 7 = 4$
- 합동 : $a \equiv b \pmod{m} \Leftrightarrow$ 나머지가 같음
 - $12 \equiv 3 \equiv 21 \pmod{9}$

성질 : 중간 계산마다 mod를 취해도 결과가 같음

- $(a + b) \bmod m = ((a \bmod m) + (b \bmod m)) \bmod m$ (곱셈도 동일)
 - $(13 + 25 + 102) \bmod 17 = (13 + 8 + 0) \bmod 17 = 4$
 - $3^4 \bmod 7 = 81 \bmod 7 = 4$

모듈러 연산 = 결과가 항상 정해진 범위($0 \sim m-1$) 안에 머무는 계산 → 순환하는 암호, 공개키 암호의 기반

03. 암호를 위한 기초 연산

모듈러 연산으로 표현한 덧셈 암호

A	B	C	D	E	F	G	H	I	J	K	L	M
0	1	2	3	4	5	6	7	8	9	10	11	12
N	O	P	Q	R	S	T	U	V	W	X	Y	Z
13	14	15	16	17	18	19	20	21	22	23	24	25

덧셈 암호의 수식 (키 $k \in \{0, 1, \dots, 25\}$)

암호화 : $y = (x + k) \bmod 26$
 복호화 : $x = (y - k) \bmod 26$

평문	A	T	T	A	C	K
x	0	19	19	0	2	10
x + 7	7	26	26	7	9	17
mod 26	7	0	0	7	9	17
암호문	h	a	a	h	j	r

키 $k = 7$: ATTACK → haahjr (Z 다음은 다시 A로 순환)

덧셈 암호는 안전한가?

- 키가 26가지뿐 → 모두 대입하면 즉시 해독 (전사적 공격)
- 글자 빈도가 그대로 남음 → 빈도 분석으로 해독

최대공약수와 모듈러 곱셈 역원 (개념)

최대공약수 (gcd)

- 두 수를 모두 나누는 가장 큰 수
 - $\text{gcd}(3, 10) = 1 \rightarrow$ 서로소
 - $\text{gcd}(2, 10) = 2$
- 큰 수 : 유클리드 알고리즘으로 계산

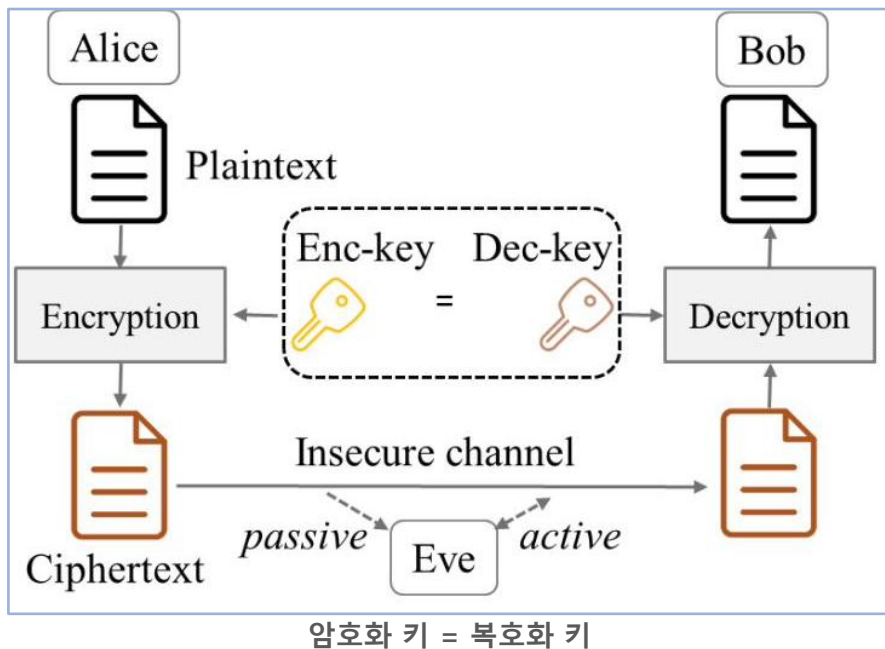
모듈러 곱셈 역원

- $a \cdot a^{-1} \equiv 1 \pmod{m}$
 - $3 \cdot 7 = 21 \equiv 1 \pmod{10} \rightarrow 3^{-1} = 7$
 - $2 \cdot x$ 는 항상 짝수 $\rightarrow$ 역원 없음
- 존재 조건 : $\text{gcd}(a, m) = 1$

x	1	2	3	4	5	6	7	8	9
$3 \cdot x \pmod{10}$	3	6	9	2	5	8	1	4	7
$2 \cdot x \pmod{10}$	2	4	6	8	0	2	4	6	8

기억할 것 : 역원이 존재하려면 a와 m이 서로소 ($\text{gcd}(a, m) = 1$)
(구체적인 계산 절차는 공개키 암호의 키 생성에서 활용)

대칭키 암호 (Symmetric-key Cryptography)



비유 : 앨리스와 밥만 열쇠 복사본을 가진 금고

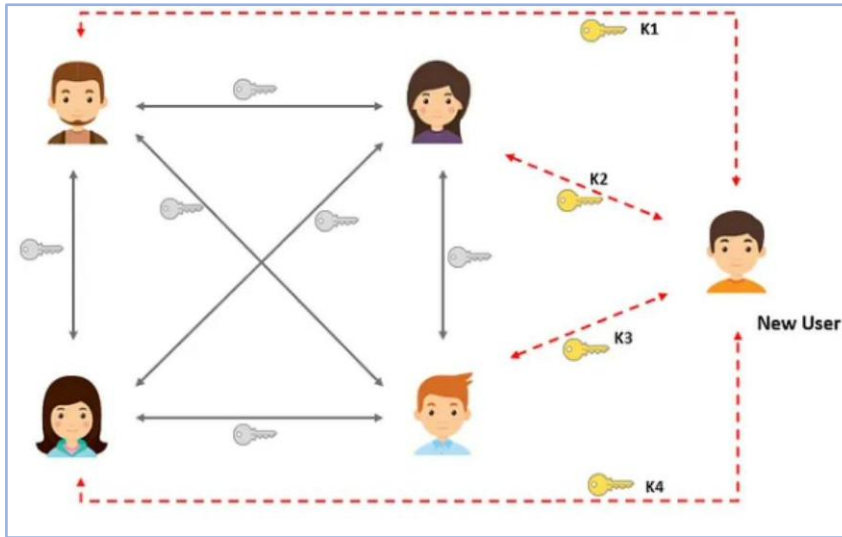
특징

- 암호화 키 = 복호화 키 (비밀키 암호)
- 단순 연산 반복 → 매우 빠름
 - 대용량 데이터, 저장 데이터 암호화에 적합
 - 주민등록번호 · 계좌번호 · 파일 · 백업 암호화

대칭키 암호의 과제 : 통신 전에 같은 키를 안전하게 나눠 가져야 함
→ "안전한 통신"의 문제가 "키를 안전하게 전달 · 보관하는" 문제로 바뀜

04. 암호 기술의 종류

대칭키 암호의 키 분배 문제



대칭키 암호 : 두 사람마다 키 1개 (새 사용자는 모두와 새 키 공유)



공개키 암호 : 각자 키 쌍 1개 (새 사용자는 자기 키 쌍만)

사용자 수 n	10	100	1,000	10,000
대칭키 $n(n-1)/2$	45	4,950	499,500	49,995,000
공개키 $2n$	20	200	2,000	20,000

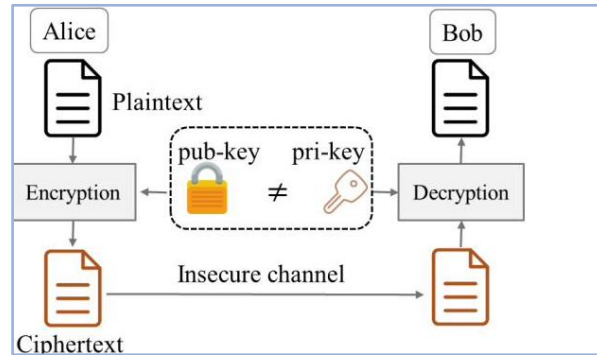
대칭키 암호의 두 가지 한계 : ① 키 개수가 사용자 수의 제곱에 비례
 ② 같은 키를 공유하므로 부인방지 불가
 → 공개키 암호의 등장 배경

04. 암호 기술의 종류

공개키 암호 (Public-key Cryptography)



누구나 넣을 수 있지만 주인만 꺼냄



공개 자물쇠로 잠그고, 개인키로만 연다

핵심 개념

- 공개키 : 누구에게나 공개 (암호화)
- 개인키 : 소유자만 보관 (복호화)
 - 미리 비밀 공유 없이 안전한 통신 → 키 분배 문제 해결
- 기반 : 한 방향은 쉽고 반대는 어려운 수학 문제
 - 예 : 소수의 곱은 쉽지만, 큰 수의 소인수분해는 어려움

공개키 암호의 과제 : 대칭키 암호보다 훨씬 느림 / 이 공개키가 정말 밥의 것인가? → 인증서로 확인

대칭키 암호와 공개키 암호의 비교

구분	대칭키 암호	공개키 암호
키 구성	비밀키 1개를 양측이 공유	공개키 + 개인키 한 쌍
키 분배	사전에 안전한 채널 필요	공개키 공개 (진위 확인 위해 인증서 필요)
n명의 키 개수	$n(n-1)/2$	$2n$ (n쌍)
속도	매우 빠름	느림
같은 안전성의 키 길이	짧음	훨씬 김 (수학적 구조 때문)
기반 원리	바꾸고 섞는 연산의 반복	한 방향만 쉬운 수학 문제
제공 기능	기밀성, 메시지 인증	기밀성, 키 교환, 전자서명(부인방지)
주 용도	대용량 데이터 암호화	키 교환, 전자서명, 소량 데이터

경쟁이 아닌 보완 관계 → 공개키로 키를 전달하고 대칭키로 데이터를 암호화 = 하이브리드 방식

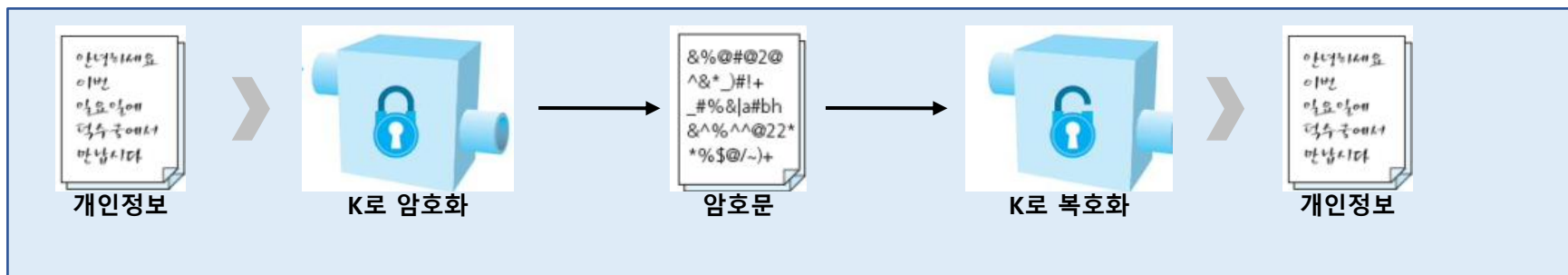
04. 암호 기술의 종류

하이브리드 방식 : 두 암호의 장점을 결합

① 키 전달 : 공개키 암호



② 데이터 전달 : 대칭키 암호 (같은 세션 키 K 사용)



공개키 암호 → 키 분배 문제 해결 + 대칭키 암호 → 속도 문제 해결
 예 : 브라우저 주소창에 자물쇠가 표시되는 HTTPS 통신

04. 암호 기술의 종류

무결성과 인증을 위한 암호 기술

해시 함수

- 임의 길이 → 짧은 고정 길이 값
- "데이터의 지문"
- 1글자만 바뀌어도 완전히 다른 값
- 출력으로 입력을 되찾을 수 없음
- **키 없음**
 - 용도 : 변경 확인, 비밀번호 저장

메시지 인증 코드 (MAC)

- 데이터 + 비밀키 → 확인값
- 키를 가진 사람만 만들 수 있음
- 무결성 + 출처 인증
- **송 · 수신자가 같은 키**
 - → 부인방지 불가

전자서명

- 개인키로 서명
- 공개키로 누구나 검증
- 무결성 + 인증 + 부인방지
- **서명자만 개인키 보유**
 - → 제3자에게 증명 가능

	사용하는 키	무결성	출처 인증	부인방지
해시 함수	없음	△ (단독으로는 제한적)	—	—
MAC	공유 비밀키	●	●	—
전자서명	개인키 / 공개키	●	●	●

04. 암호 기술의 종류

보안 목표와 암호 기술의 대응

보안 목표	대칭키 암호	공개키 암호	해시 함수	MAC	전자서명
기밀성	●	●	—	—	—
무결성	△	△	△	●	●
출처 인증	△	—	—	●	●
부인방지	—	—	—	—	●
키 교환	—	●	—	—	—

● 제공 △ 조건부 · 단독으로는 불충분 — 제공하지 않음

암호화만으로는 무결성이 보장되지 않는다

- 공격자는 내용을 몰라도 암호문을 바꾸거나 잘라내거나 바꿔치기할 수 있음
- 해결 : 암호화 + 메시지 인증을 함께 사용 (또는 둘을 결합한 방식)

하나의 기술이 모든 목표를 제공하지 않음 → 목표에 맞게 조합 / 부인방지는 전자서명만 제공

케르크호프스의 원리 (Kerckhoffs's Principle)



"암호 시스템은 키를 제외한 모든 것이 공격자에게 알려져도 안전해야 한다"
 — A. Kerckhoffs, 1883
 → 안전성은 알고리즘의 비밀이 아니라 오직 "키의 비밀"에 의존

왜 키에만 의존해야 하는가

- 알고리즘은 구현되면 역공학으로 노출 / 짧은 무작위 키는 노출 어려움
- 노출 시 : 알고리즘 → 전체 재설계, 키 → 키만 교체
- 공개 검증으로 약점 조기 발견, 표준화 가능

개인정보 실무 사례 (질의응답 모음집 Q51)

한글 · 엑셀 파일 비밀번호 설정
 → 암호화 조치에 해당할 수 있음

단, 파일명에 비밀번호를 적어 두면
 → 암호화로 인정되지 않음

공개 검증된 표준 알고리즘을 사용하고, 보안의 역량은 키를 지키는 데 집중

암호해독 (Cryptanalysis) 의 종류

암호해독 (Cryptanalysis)

고전적 공격 (Classical Attacks)

전사적 공격 (Brute-force)

가능한 모든 키를
하나씩 시도
(알고리즘 = 블랙박스)

수학적 분석 (Mathematical Analysis)

알고리즘의 구조를
분석해 더 효율적으로
(예 : 빈도 분석)

대상 : 암호 알고리즘 자체

구현 공격 (Implementation Attacks)

암호가 구현된 "장치"를 공격

예 : 스마트카드의 연산 시간 · 소비 전력을
측정해 키 추출 (부채널 공격)

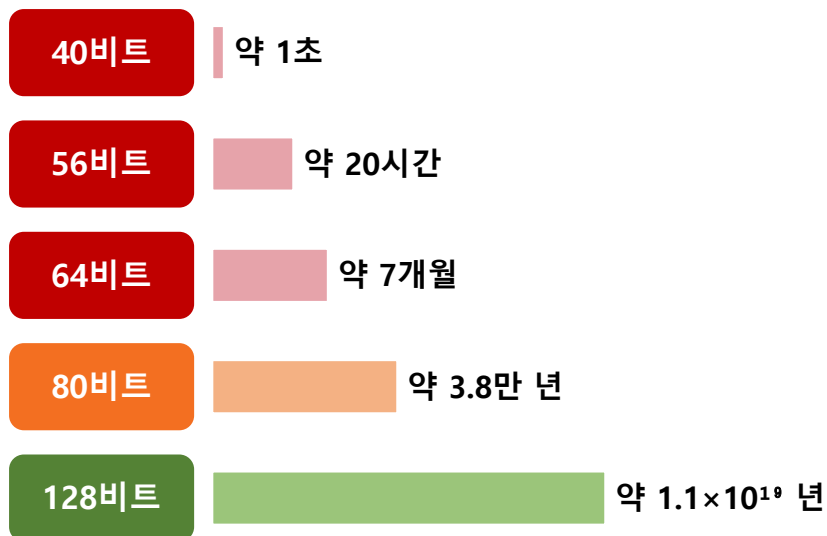
수학적으로 안전해도
구현이 부주의하면 깨질 수 있음

공격자는 단 하나의 공격만 성공하면 된다 → 큰 키 공간만으로는 안전성이 보장되지 않음
모든 가능한 공격을 견뎌야 함

전사적 공격 (Brute-force Attack) 과 키 길이

방법 : 평문-암호문 쌍 (x_0, y_0) 하나를 알고, 모든 키 K_i 에 대해 $D_{K_i}(y_0) = x_0 ?$ 를 확인
 시도 횟수 = 키 공간의 크기 (k비트 $\rightarrow$ 최대 2^k 번)

초당 10^{12} 개 키를 시험할 때 (막대 : 로그 눈금)



우주의 나이 $\approx 1.4 \times 10^{10}$ 년

키 길이	전사적 공격 기준 안전 기간
64비트	단기 (수일 이하)
128비트	장기 (수십 년, 양자 컴퓨터가 없다면)
256비트	장기 (양자 컴퓨터에도 견딤)

출처 : Paar & Pelzl, Understanding Cryptography, Ch.1

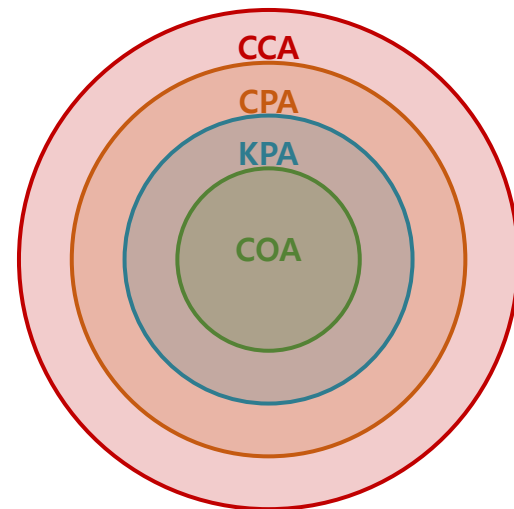
주의 : 다른 공격이 가능하면
 긴 키도 소용없음

- 키 1비트 증가 = 시간 2배 $\rightarrow$ 키 길이가 전사적 공격에 대한 안전성을 결정

05. 암호의 안전성과 공격 모델

공격 모델 : 공격자는 무엇을 가지고 있는가

공격 모델	공격자가 가진 것	비유
COA 암호문 단독 공격	암호문만	도청한 암호 편지만 가짐
KPA 알려진 평문 공격	암호문 + 일부 평문-암호문 쌍	예전 편지의 원문 몇 개를 읽음
CPA 선택 평문 공격	원하는 평문의 암호문을 얻을 수 있음	암호 기계를 잠시 쓸 수 있음
CCA 선택 암호문 공격	원하는 암호문의 복호 결과를 얻을 수 있음	해독 기계를 잠시 쓸 수 있음

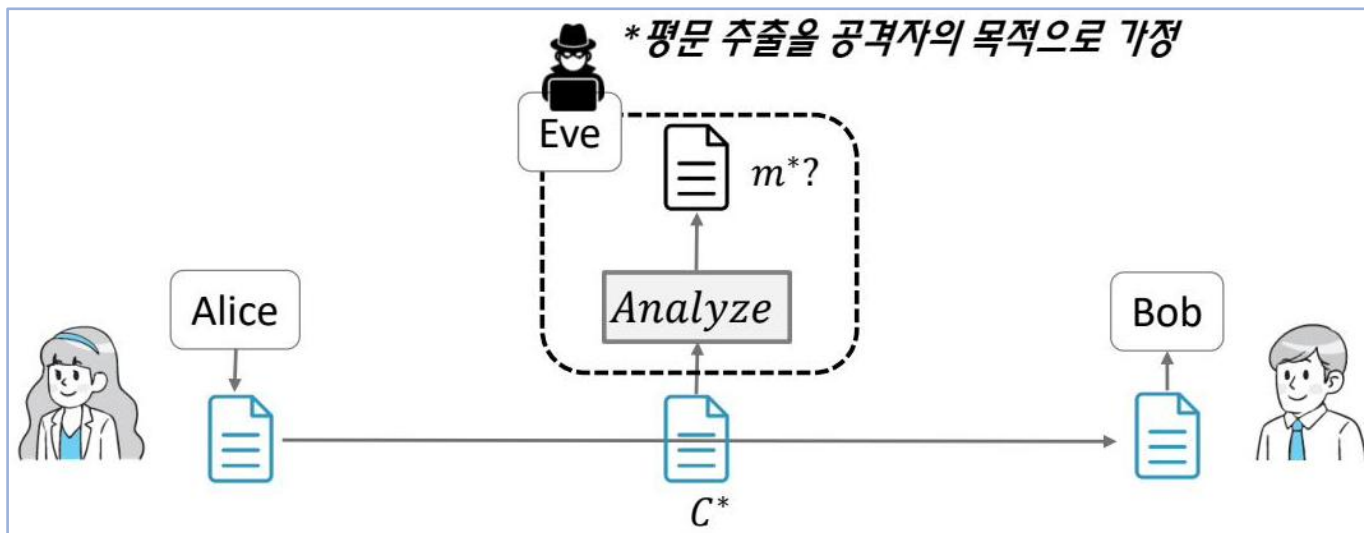


바깥일수록 강한 공격자

공격자의 능력 : $COA < KPA < CPA < CCA$
 강한 공격 모델에서 안전 $\rightarrow$ 약한 공격 모델에서도 안전

- "안전하다"는 말에는 항상 "어떤 공격자로부터"가 함께 있어야 함

암호문 단독 공격 (Ciphertext Only Attack, COA)

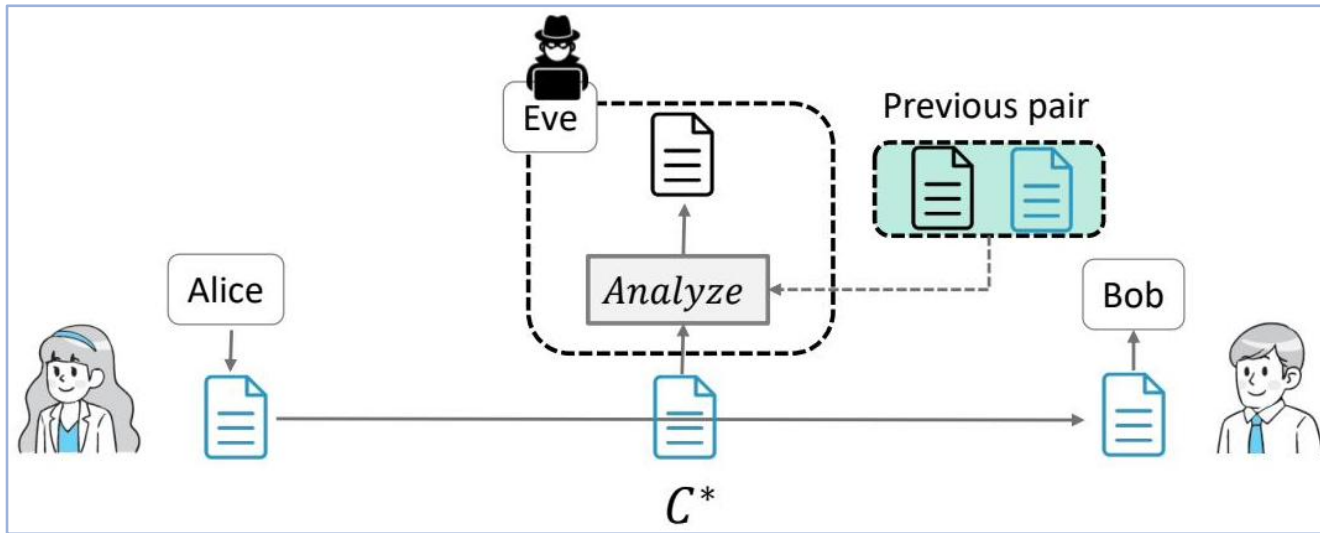


공격자가 가진 것

- 암호문 $C_1, C_2, \dots, C_n$ 만 보유
- 도청으로 누구나 얻을 수 있음
 - 가장 약한(공격자에게 불리한) 모델
 - 그러나 가장 현실적 · 기본적인 상황

- COA에서 안전하려면 : 암호문이 무작위 비트열처럼 보여 평문의 통계적 특징이 전혀 드러나지 않아야 함

알려진 평문 공격 (Known Plaintext Attack, KPA)

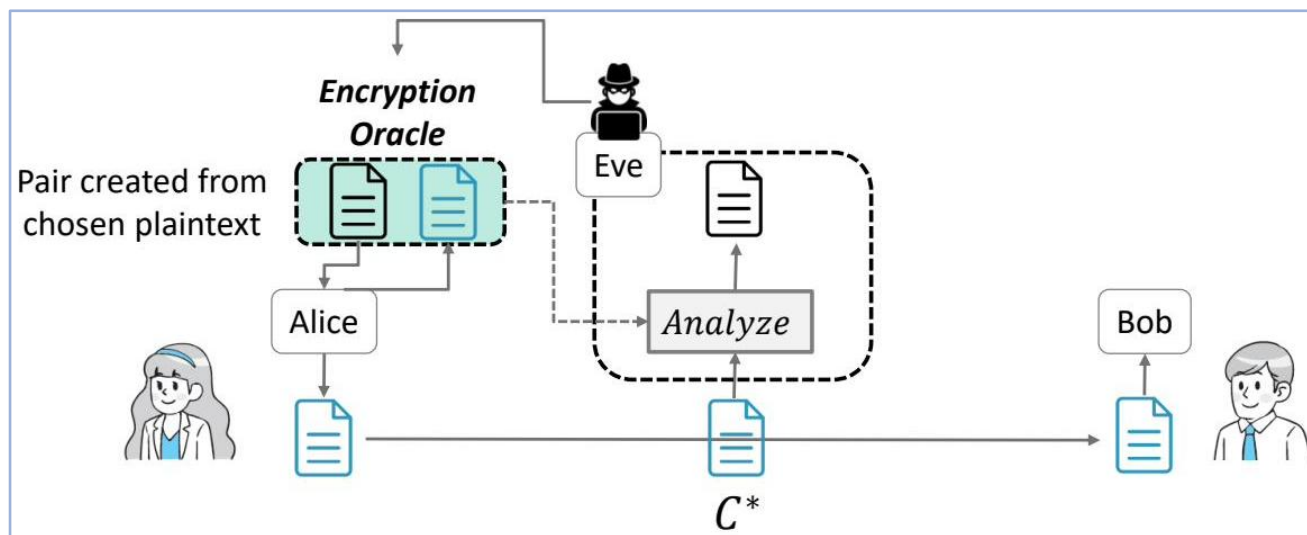


공격자가 가진 것

- 새 암호문 C^*
+ 이전 평문-암호문 쌍 $(m_1, C_1), \dots, (m_n, C_n)$
- 현실 예 :
이메일 인사말, 파일 머리 부분, 정형화된 공문서
- 에니그마 해독 : 반복되는 일기예보 문구 이용

- 현대 암호 : 많은 평문-암호문 쌍을 알아도 새 암호문의 평문 · 키를 알아낼 수 없어야 함

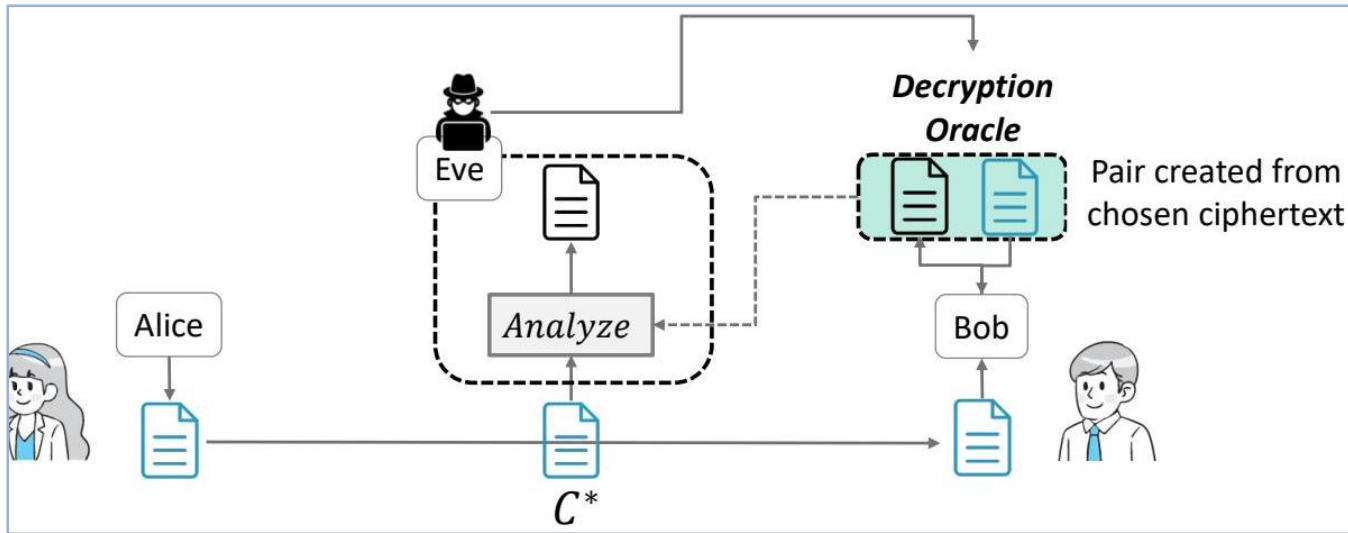
선택 평문 공격 (Chosen Plaintext Attack, CPA)



공격자가 할 수 있는 것

- 원하는 평문 $m_1, \dots, m_n$ 의 암호문을 얻을 수 있음
 - 암호화 오라클 : 키는 모르지만 암호화 기능은 사용 가능
- 현실 예 : 송신자 기기 해킹, 공격자 입력을 서버가 암호화
 - 공개키 암호 : 누구나 암호화 가능 → 항상 CPA 가정

선택 암호문 공격 (Chosen Ciphertext, CCA)



공격자가 할 수 있는 것

- 원하는 암호문의 복호 결과를 얻을 수 있음
 - 복호화 오라클 (단, 대상 암호문 C^* 는 질의 불가)
- 현실 예 : 복호화 장치 일시 사용
 - 서버의 복호화 오류 메시지 차이만으로도 평문 노출 가능

설계 원칙

- 표준 암호는 CCA에서도 안전해야 함
- 복호화 실패 원인을 자세히 알려 주지 않기

- 가장 강한 공격 모델 : 복호화 결과의 아주 작은 정보만 새어도 "복호화 오라클"이 됨

네 가지 공격 모델의 비교

모델	공격자가 가진 정보	얻는 방법	현실 예
COA	암호문	도청 (수동적)	무선 · 인터넷 도청
KPA	암호문 + 일부 평문-암호문 쌍	도청 + 평문 추측 (수동적)	정형화된 문서 · 헤더
CPA	원하는 평문의 암호문	암호화 기능 사용 (능동적)	공개키 암호, 기기 해킹
CCA	원하는 암호문의 평문	복호화 기능 사용 (능동적)	복호화 오류 응답 관찰

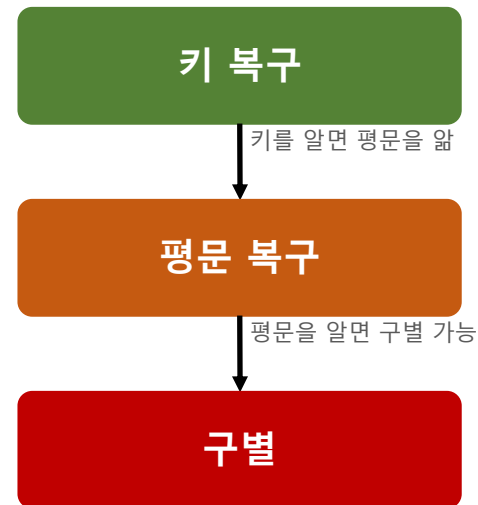
공격자의 능력 : COA < KPA < CPA < CCA

강한 공격 모델에서 안전할수록 더 안전한 암호
 → 표준 암호는 CPA · CCA에서도 안전하도록 설계 (공격자에게 최대한 유리한 조건을 가정)

06. 안전성의 목표와 수준

공격자의 목표 : 무엇을 알아내면 "깨졌다"고 할까

공격자의 목표	의미	난이도
키 복구 (Key Recovery)	키를 찾아 모든 암호문 해독 → 시스템 완전 붕괴	가장 어려움
평문 복구 (One-Wayness, OW)	키는 몰라도 주어진 암호문의 평문 전체를 알아냄	중간
구별 (Indistinguishability, IND)	평문에 대한 작은 정보라도 알아냄 (두 후보 중 어느 것인가, 첫 비트는?)	가장 쉬움



가장 쉬운 목표(구별)조차 불가능 → 평문 복구 · 키 복구도 불가능
→ 현대 암호는 "구별 불가능성"을 기준으로 안전성을 정의

06. 안전성의 목표와 수준

왜 "작은 정보"까지 막아야 하는가

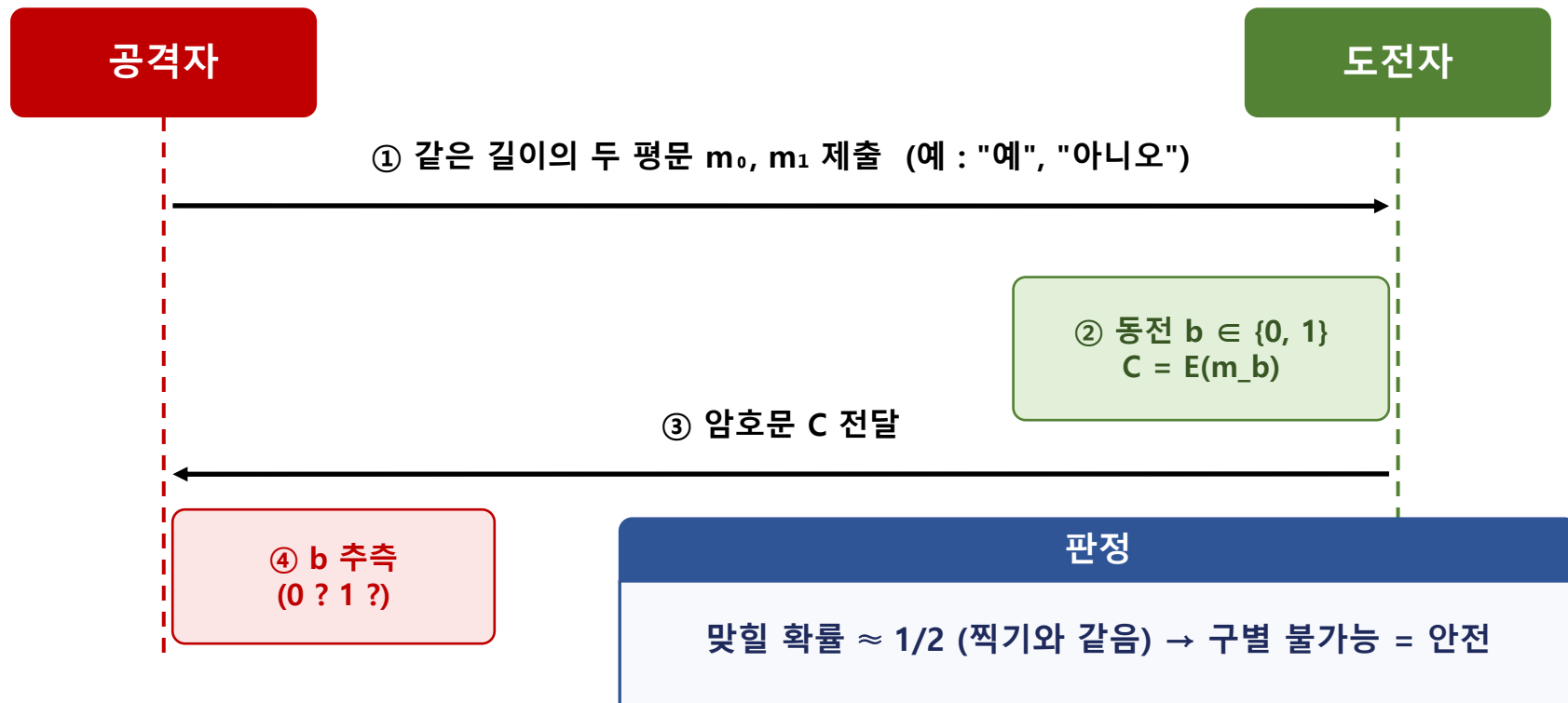
개인정보 예	가능한 평문	구별만 해도 드러나는 것
설문 : 특정 질환 여부	예 / 아니오	응답 전체
검사 결과	양성 / 음성	검사 결과 전체
성별 · 혼인 여부	2 ~ 3가지	해당 항목 전체
급여 수준	구간 (예 : 5개)	소득 구간
같은 값의 반복	같은 평문 → 같은 암호문?	누구와 누가 같은 값인지

암호의 진짜 목표

- 평문 "전체"를 숨기는 것이 아니라
- 암호문을 보고 평문에 대해 알 수 있는 것이 "전혀 없게" 만드는 것
- = 암호문은 무작위 값과 구별되지 않아야 함

개인정보에서는 "작은 정보"가 곧 "전부"인 경우가 많다 → 구별 불가능성이 필요한 이유

구별 불가능성 (IND) 게임



게임 중 공격자가 추가로 쓸 수 있는 것	안전성 개념
암호화 오라클	IND-CPA
암호화 오라클 + 복호화 오라클 (단, 도전 암호문 C는 질의 불가)	IND-CCA

IND 게임 예 : 같은 평문 → 같은 암호문이면?

CPA 공격자의 전략 (결정적 암호화)

- ① $m_0 = \text{"예"}, m_1 = \text{"아니오"}$ 제출
- ② 도전자 $\rightarrow C = E(m_b)$
- ③ 암호화 오라클에 "예"를 넣어 $C' = E(\text{"예"})$ 획득
- ④ $C = C'$ 이면 $b = 0$, 아니면 $b = 1$

→ 키를 몰라도 100 % 정답

실제 문제 : 암호화된 설문 응답

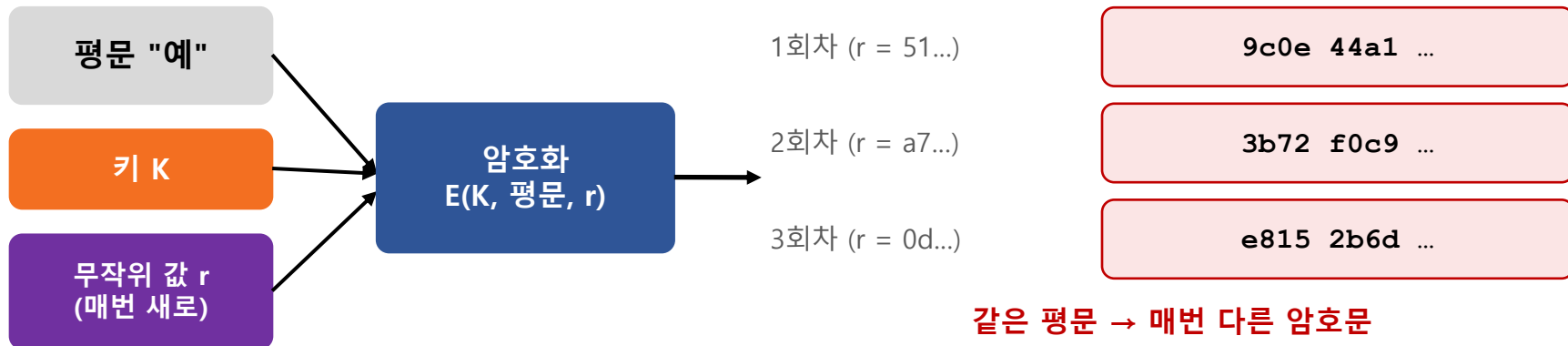
응답자	저장된 암호문
A	7f3a...
B	c21e...
C	7f3a...
D (공격자)	7f3a...

공격자 D의 답이 "예"
→ 같은 암호문인 A, C도 "예"

결정적 암호화 (같은 평문 → 항상 같은 암호문) 는 IND-CPA를 만족하지 못함
→ 안전한 암호화 : 같은 평문도 매번 다른 암호문이 나와야 함

06. 안전성의 목표와 수준

확률적 암호화 : 매번 다른 암호문



특징
■ r은 비밀이 아님 → 암호문과 함께 전달 ■ 복호화의 정확성은 그대로 유지 ■ IND 게임의 비교 공격이 무의미해짐 ■ r은 예측 불가능해야 하고, 방식에 따라 재사용 금지

응답자	저장된 암호문
A ("예")	9c0e...
C ("예")	3b72...
D ("예")	e815...

→ 누가 같은 답을 했는지 알 수 없음

현대 암호의 기본 : 블록 암호의 "운영 모드", 공개키 암호의 암호화 방식 모두 이 성질을 갖추도록 설계

06. 안전성의 목표와 수준

안전성 수준 : 공격 목표 × 공격 모델

목표 W 모델	COA	KPA	CPA	CCA	예와 표준의 요구
구별 (IND) 가장 쉬운 목표	IND-COA	IND-KPA	IND-CPA	IND-CCA 가장 강함	■ 덧셈 · 치환 암호 : KR-COA조차 불만족 ■ 결정적 암호화 : IND-CPA 불만족 ■ 표준 암호화 방식 : 최소 IND-CPA, 가능하면 IND-CCA
평문 복구 (OW)	OW-COA	OW-KPA	OW-CPA	OW-CCA	
키 복구 (KR) 가장 어려운 목표	KR-COA 가장 약함	KR-KPA	KR-CPA	KR-CCA	

→ 공격자 능력 강함

알고리즘 이름만으로 안전성이 결정되지 않음 → "어떻게 사용하는가"가 안전성을 좌우

- 가장 강한 공격자가 가장 쉬운 목표조차 달성하지 못할 때 = 가장 높은 안전성 (IND-CCA)

06. 안전성의 목표와 수준

무조건적 안전성과 계산적 안전성

무조건적 안전성 (Unconditional)

- 무한한 계산 능력으로도 깨지지 않음
 - 정보이론적 안전성, 완전 비밀성 (샤논)
- 암호문에서 평문 정보를 전혀 얻을 수 없음
 - 예 : 일회용 패드
- 조건 : 키 길이 $\geq$ 평문 길이 $\rightarrow$ 실용성 낮음

계산적 안전성 (Computational)

- 현실적 계산 능력으로 합리적 시간 내 해독 불가
 - 해독 시간 $\gg$ 우주의 나이
- 오늘날 사용하는 거의 모든 암호
- 전제 : 수학 문제의 어려움 + 현실적 계산 능력
 - 컴퓨터 발전 · 양자 컴퓨터 등장 시 흔들릴 수 있음

구분	무조건적 안전성	계산적 안전성
공격자 가정	무한한 계산 능력	현실적 계산 능력
근거	정보이론 (증명)	수학 문제의 어려움 (가정)
키 길이	평문 이상	짧은 고정 길이 (예 : 128비트)
예	일회용 패드	현대 암호 대부분

계산적 안전성은 시간에 따라 변함 $\rightarrow$ 장기 보관 개인정보는 "보관 기간 동안의 안전성"까지 고려

일회용 패드 (One-Time Pad) : 완전 비밀성의 예

$$C = P \oplus K, P = C \oplus K$$

평문 P	10110011
$\oplus$ 키 K	01101100
= 암호문 C	11011111
$\oplus$ 키 K	01101100
= 평문 P	10110011

암호문 11011111은 적절한 키를 고르면 어떤 8비트 평문에서도 나올 수 있음 $\rightarrow$ 평문을 특정할 수 없음

완전 비밀성의 3가지 조건

- 키 길이 $\geq$ 평문 길이
- 키는 진정한 난수 (예측 불가)
- 키는 한 번만 사용 (재사용 금지)

키 재사용의 위험

$$C_1 \oplus C_2 = (P_1 \oplus K) \oplus (P_2 \oplus K) \\ = P_1 \oplus P_2 \text{ (키가 상쇄됨)}$$

실제 사례 : 1940년대 소련 암호 통신의 키 재사용 $\rightarrow$ 해독

한계 : 평문만큼 긴 키를 안전하게 나눠 가져야 함 $\rightarrow$ 비실용적
 $\rightarrow$ 짧은 키로 긴 키 스트림을 만드는 "스트림 암호"로 실용화

- 같은 키 · 같은 무작위 값의 재사용 금지는 현대 암호 전체에 적용되는 원칙

난수와 키 관리 : 안전성의 실질적 기반

난수 : 키는 예측할 수 없어야 한다

- 암호 키 · 무작위 값 = 예측 불가능한 난수
- 일반 난수 함수 : 시작값을 알면 재현 가능
→ 암호용 사용 금지
- 암호용 안전한 난수 발생기 사용
 - 실패 사례 : 현재 시각 · 프로세스 번호로 키 생성
→ 수 분 만에 추측
 - 안전성 확보조치 기준 안내서 :
안전한 난수발생기(RNG) 이용

키 관리 : 키는 조직이 지켜야 한다

생성

분배

저장 · 사용

갱신

폐기

- 키와 암호화된 데이터를 분리 보관
- 소스 코드 · 설정 파일에 키 기록 금지
- 키 접근자 최소화, 접근 기록
- 키 분실 = 데이터 영구 손실 → 안전한 백업

알고리즘은 공개된 표준을 쓰면 되지만, 키는 각 조직이 스스로 지켜야 한다

- 키 길이가 길어도 키 생성이 예측 가능하면 실제 키 공간은 훨씬 작아짐

핵심 정리 (1)

보안 목표

- CIA + 인증 · 부인방지 · 책임추적성, 목표 사이의 균형
- 소극적 공격 → 예방(암호화) / 적극적 공격 → 탐지 · 복구

암호의 개념

- 암호 = 내용 은닉, 스테가노그래피 = 존재 은닉
- 암호기법(설계) + 암호해독(분석), 방법을 숨기는 기술 → 공개 · 검증하는 과학

기초 연산

- XOR : $(A \oplus K) \oplus K = A$, 모듈러 연산 : 덧셈 암호 $y = (x + k) \bmod 26$
- 곱셈 역원은 $\gcd(a, m) = 1$ 일 때만 존재

암호 기술

- 대칭키 : 빠름, 키 $n(n-1)/2$ / 공개키 : 키 분배 해결, 느림 → 하이브리드
- 해시(키 없음) · MAC(부인방지 불가) · 전자서명(부인방지)

핵심 정리 (2)

안전성의 원칙

- 케르크호프스 : 안전성은 키의 비밀에만 의존
- 고전적 공격(전사적 · 수학적 분석) + 구현 공격, 큰 키 공간 $\neq$ 안전

공격 모델

- $\text{COA}(\text{암호문}) < \text{KPA}(\text{쌍}) < \text{CPA}(\text{암호화 오라클}) < \text{CCA}(\text{복호화 오라클})$
- 강한 모델에서 안전할수록 더 안전

목표와 IND

- 키 복구 > 평문 복구 > 구별 (쉬움), IND = 맞힐 확률 $\approx 1/2$
- 결정적 암호화 $\rightarrow$ IND-CPA 불만족 $\rightarrow$ 확률적 암호화, 최강 IND-CCA

안전성 수준 · 키

- 무조건적(일회용 패드) vs 계산적(시간에 따라 변함)
- 안전한 난수 · 키 분리 관리



hank You

E-mail: seyoung@kangwon.ac.kr